Website Vulnerability Assessment & Penetration Test Report

Target: https://google-gruyere.appspot.com/

google-gruyere.appspot.com_VAPT_Report
Generated 2026-11-09 06:28:04Z

Generated by Automated Website VAPT Framework v1.0.0 by Shrayan Biswas · LinkedIn

1. Executive summary

7 findings recorded for https://google-gruyere.appspot.com/: 0 Critical, 0 High, 2 Medium, 3 Low, 2 Informational. Automated checks are indicators and must be validated; items marked CANDIDATE need manual confirmation.

2. Scope

Scope: https://google-gruyere.appspot.com/. Testing consisted of non-destructive automated checks plus any manual findings recorded in this register.

3. Methodology

OWASP WSTG-aligned phases: reconnaissance, attack-surface mapping, configuration, authentication, authorization, input validation, session, API, client-side, validation, CVSS 3.1 scoring.

4. Environment and tools

Python 3 (urllib, ssl, socket), Flask; optional: Nmap, WhatWeb, Nikto, SSLScan; manual: Burp Suite, OWASP ZAP, SQLmap

5. Scans performed

Scan	Started (UTC)	Status	Requests	Modules
5e6baaeb	2026-11-09 06:18:44Z	done	112	recon, headers, cookies, tls, cors, methods, endpoints, directories, api, frontend, external

6. Vulnerability summary

ID	Title	Severity	CVSS	Status
8bca6e12	Missing Content-Security-Policy header	**Medium**	4.2	Open
800092c6	Missing clickjacking protection	**Medium**	4.2	Open
20458efa	Missing X-Content-Type-Options header	Low	3.1	Open
7c505fea	Missing Strict-Transport-Security header	Low	3.1	Open
9fb9a0c8	Cookie 'GRUYERE_ID' missing Secure, HttpOnly, SameSite	Low	3.1	Open
c34cd306	Missing Referrer-Policy header	*Informational*	0.0	Open
fa5d3a63	Missing Permissions-Policy header	*Informational*	0.0	Open

7. Detailed findings

8bca6e12 - Missing Content-Security-Policy header

Severity: Medium (CVSS 4.2, `CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:L/A:N`)
Affected component: `/` **Phase:** Phase 3 **Status:** Open

Description: No CSP is sent, which reduces defence-in-depth against XSS and data injection.

Impact / business impact: Weakens browser-side protections.

Proof of concept / evidence:

```
Header 'content-security-policy' absent from response.
```

Recommendation: Add: Content-Security-Policy: default-src 'self'; frame-ancestors 'self' (tune for the app)

Retest notes: Not yet retested

800092c6 - Missing clickjacking protection

Severity: Medium (CVSS 4.2, `CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:L/A:N`)
Affected component: `/` **Phase:** Phase 9 **Status:** Open

Description: Neither X-Frame-Options nor CSP frame-ancestors is present.

Impact / business impact: Page may be framed by a malicious site (clickjacking).

Proof of concept / evidence:

```
See evidence/ folder
```

Recommendation: Add X-Frame-Options: DENY (or SAMEORIGIN) or CSP frame-ancestors.

Retest notes: Not yet retested

20458efa - Missing X-Content-Type-Options header

Severity: Low (CVSS 3.1, `CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N`)
Affected component: `/` **Phase:** Phase 3 **Status:** Open

Description: Browsers may MIME-sniff responses.

Impact / business impact: Weakens browser-side protections.

Proof of concept / evidence:

```
Header 'x-content-type-options' absent from response.
```

Recommendation: Add: X-Content-Type-Options: nosniff

Retest notes: Not yet retested

7c505fea - Missing Strict-Transport-Security header

Severity: Low (CVSS 3.1, `CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N`)
Affected component: `/` **Phase:** Phase 3 **Status:** Open

Description: HSTS not set on an HTTPS site.

Impact / business impact: Downgrade / SSL-strip risk.

Proof of concept / evidence:

```
See evidence/ folder
```

Recommendation: Strict-Transport-Security: max-age=31536000; includeSubDomains

Retest notes: Not yet retested

9fb9a0c8 - Cookie 'GRUYERE_ID' missing Secure, HttpOnly, SameSite

Severity: Low (CVSS 3.1, `CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N`)
Affected component: `Set-Cookie` **Phase:** Phase 7 **Status:** Open

Description: Cookie lacks recommended security attributes.

Impact / business impact: Increased exposure to theft or CSRF.

Proof of concept / evidence:

```
GRUYERE_ID=<redacted>; path=/
```

Recommendation: Set Secure, HttpOnly and SameSite=Lax/Strict on session cookies.

Retest notes: Not yet retested

c34cd306 - Missing Referrer-Policy header

Severity: *Informational* (CVSS 0.0, `CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:N`)
Affected component: `/` **Phase:** Phase 3 **Status:** Open

Description: Full URLs may leak to third parties via the Referer header.

Impact / business impact: Weakens browser-side protections.

Proof of concept / evidence:

```
Header 'referrer-policy' absent from response.
```

Recommendation: Add: Referrer-Policy: strict-origin-when-cross-origin

Retest notes: Not yet retested

---

fa5d3a63 - Missing Permissions-Policy header

Severity: *Informational* (CVSS 0.0, `CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:N`)
Affected component: `/` **Phase:** Phase 3 **Status:** Open

Description: Browser features are not explicitly restricted.

Impact / business impact: Weakens browser-side protections.

Proof of concept / evidence:

```
Header 'permissions-policy' absent from response.
```

Recommendation: Add: Permissions-Policy: geolocation=(), camera=(), microphone=()

Retest notes: Not yet retested

8. Retesting results

- No retests recorded yet.

9. Conclusion

Prioritise Critical/High items, then re-run the scan and update statuses to Retest Passed.

Automated Website VAPT Framework v1.0.0 © 2026 Shrayan Biswas · MIT License · https://www.linkedin.com/in/shrayan-biswas-a1259225a/